

Target: <https://httpbin.org/get>

Scanned: 2026-06-23T18:09:23.091783+00:00

Overall Risk: HIGH

Checks Run: 6

Summary

HIGH	MEDIUM	LOW	PASS	ERROR
2	1	0	3	0

Findings

API5 - Security Misconfiguration

MEDIUM

→ Server header exposed: *unicorn/19.9.0*

→ CORS wildcard (*) allows all origins

```
{'status_code': 200, 'headers': {'Date': 'Tue, 23 Jun 2026 18:08:50 GMT', 'Content-Type': 'application/json', 'Content-Length': '313', 'Connection': 'keep-alive', 'Server': 'unicorn/19.9.0', 'Access-Control-Allow-Origin': '*', 'Access-Control-Allow-Credentials': 'true'}}
```

API4 - Rate Limiting Absence

HIGH

→ No rate limiting detected after 15 rapid requests

```
{'status_codes': [200, 200, 200, 200, 200, 200, 200, 200, 200, 200, 200, 200, 200, 200, 200]}
```

API1 - Broken Object Level Authorization

PASS

→ No BOLA indicators detected

```
[{'url': 'https://httpbin.org/get/1', 'status_code': 404}, {'url': 'https://httpbin.org/get/2', 'status_code': 404}, {'url': 'https://httpbin.org/get/3', 'status_code': 404}, {'url': 'https://httpbin.org/get/99', 'status_code': 404}, {'url': 'https://httpbin.org/get/100', 'status_code': 404}]
```

API2 - Broken Authentication

HIGH

→ Endpoint accessible with no authentication

→ Endpoint accessible with invalid token

```
{'no_auth_status': 200, 'bad_auth_status': 200}
```

API3 - Excessive Data Exposure

PASS

→ *No sensitive fields detected in response*

```
{'status_code': 200, 'response_preview': '{\n  "args": {}, \n  "headers": {\n    "Accept": "*/*", \n    "Accept-Encoding": "gzip, deflate, br", \n    "Host": "httpbin.org", \n    "User-Agent": "python-requests/2.32.5", \n    "X-Amzn-Trace-Id": "Root=1-6a3acbd1-5a8c8f0f728356057ed2171d"\n  }, \n  "origin": "197.235.155.158", \n  "url": "https://httpbin.org/get"\n}\n'}
```

API6 - Mass Assignment

PASS

→ *Response is not JSON - skipping field analysis*

```
{'status_code': 405, 'response_preview': '\n405 Method Not Allowed\nMethod Not Allowed\nThe method is not allowed for the requested URL.\n'}
```